

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

System and Services Acquisition Policy and Procedures (SA)

System and Services Acquisition Policy and Procedures (SA)

Table of Contents

1.0. Document Purpose 2

2.0. Scope 2

3.0. Policy Conflict 2

4.0. Roles and Responsibilities 2

5.0. Management Commitment 6

6.0. Coordination Among Agency Entities 6

7.0. Compliance 6

8.0. Procedures 6

9.0. Document Details 21

10.0. Review 22

11.0. Records Management 22

12.0. Public Records Exceptions 22

13.0. Definitions 22

14.0. Abbreviations 26

Appendix A: Cloud Service Provider Security 28

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place to ensure the secure acquisition, development, and management of information systems and services (see Definitions). This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets through structured acquisition practices, vendor oversight, and lifecycle controls. This document corresponds to the System and Service Acquisition (SA) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5). [1].

2.0. Scope

2.1. This policy applies to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Policy Conflict

If this policy conflicts with any applicable law or union contract, the terms of the existing law or contract shall prevail.

4.0. Roles and Responsibilities

4.1. Agencies are responsible for:

4.1.1. Working with the PMO to ensure projects are successful and return the expected value to the organization;

4.1.2. Proper *Traffic Light Protocol (TLP)* classification of the data used and held by the agency and its vendors in accordance with Risk Assessment Policy and Procedures; [2]

4.1.3. Ensuring that funding for the acquisition is adequate for sustaining the system/service beyond the initial purchase;

4.1.4. Ensuring compliance with the Maine Department of Treasury's Credit Card Information Security Policy and Guidelines, [3] as well as taking responsibility for any fines levied as a result of Payment Card Industry Data Security Standard non-compliance;

4.1.5. Ensuring security functional requirements are part of the acquisition process for hardware, software, or firmware; and

---

1 https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/risk-assessment-policy-procedure.pdf
[3] https://www1.maine.gov/treasurer/private/CreditCardProcessingPolicyWithAttachments.pdf

4.1.6. Ensuring agency personnel are aware of the applicable penalties for non-compliance.

4.2. Chief Information Officer (CIO)

4.2.1. Is responsible for certifying that effective security controls are in place in the system acquisition, development, and management process for the protection of the State of Maine's information systems and assets;

4.2.2. Is responsible for certifying that effective fiscal controls are in place for system and services acquisition, development, and management;

4.2.3. Is responsible for approving the security requirement budget requests submitted by the Chief Information Security Officer (CISO); and

4.2.4. Is responsible for providing the Information Security Office (ISO) with appropriate resources to secure the enterprise through the coordination, development, implementation, and maintenance of an enterprise-wide information security program.

4.3. Chief Information Security Officer (CISO):

4.3.1. Prioritizing information security services and authorizing any security exceptions;

4.3.2. Identifying appropriate resources for allocation in information security budgeting, planning, and documentation;

4.3.3. Performing security assessments to determine information security gaps at the enterprise level and documenting those gaps in the Plan of Action and Milestones (POA&M);

4.3.4. Defining the security and compliance requirements of services and equipment;

4.3.5. Ensuring that IT vendor-managed and contracted services and equipment are secure;

4.3.6. Co-approving the acquisition of services and equipment that affect existing technology with the Enterprise Architect; and

4.3.7. Owning, executing, and enforcing this document.

4.4. Contract Administrator:

4.4.1. Monitoring vendor performance to ensure vendor adherence to contract provisions throughout the contract, including ongoing maintenance and support;

4.4.2. Providing all vendor third-party audit reports and information security documentation to the ISO for review;

4.4.3. Reviewing all services, outputs, and products provided by third parties at least annually; and

4.4.4. Maintaining contract-related documentation, including security documentation.

4.5. DAFS IT Procurement:

4.5.1. Managing and guiding the IT procurement process for all IT-related acquisitions;

4.5.2. Working with stakeholders to include State of Maine agencies, OIT teams, and vendors to ensure that vendor contracts are executed in accordance with applicable federal and state regulations, OIT policies, procedures, and standards;

4.5.3. Working with agencies to ensure that contracts for vendor-hosted or vendor-managed agency information assets include the requisite contract language to safeguard the data at risk in accordance with applicable federal and state regulations, and OIT policies, procedures, and standards;

4.6. OIT Applications Development:

4.6.1. Working with agencies to ensure that:

4.6.1.1. Vendors meet the necessary security requirements; and

4.6.1.2. Any requested exceptions are submitted for evaluation and final approval by the CIO or the CISO through the waiver process.

4.7. OIT Change Advisory Board (CAB):

4.7.1. Maintaining the Change Management policies, which enable system engineers, architects, and security analysts to expediently perform their necessary business functions, yet maintain a controlled, secure, and functioning environment (see OIT Change Management Policy and Procedures). [4]

4.8. OIT Enterprise Architecture:

4.8.1. Managing the Enterprise Architecture Review Board, which evaluates strategic architectural decisions and ensures alignment with enterprise principles;

4.8.2. Facilitating the Design Review process for new technology intake, which supports solution vetting and SDLC milestones;

4.8.3. Documenting the security and compliance requirements for services and equipment; and

4.8.4. Co-approving the acquisition of services and equipment that affect existing technology with the CISO.

[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/change-management-policy.pdf

4.8.5. The Enterprise Architect convenes the Enterprise Architecture Review Board to evaluate strategic architectural decisions, ensure alignment with enterprise principles, and support governance of major acquisitions and system changes.

4.8.6. At the discretion of the Enterprise Architect, the Technical Assessment tool of I.T. RFPs may be used to assess State of Maine Applications (as defined in the Application Deployment Certification Policy[5]).

4.9. OIT Finance Director:

4.9.1. Reviewing purchase requests for services and equipment above $5,000 against available resources; and

4.9.2. Managing the OIT budget process from estimation through execution.

4.10. OIT Information Security Office (ISO):

4.10.1. Reviewing all security documentation submitted by vendors to ensure compliance with all third-party audit requirements;

4.10.2. Ensuring that information security requirements are met within the system and service acquisition process; and

4.10.3. Ensuring that the system lifecycle activities meet the security requirements for the enterprise in collaboration with the Enterprise Architect.

4.11. OIT Policy Team:

4.11.1. Establishing and maintaining policies for the acquisition of services and hardware, as well as documenting the necessary architectural requirements;

4.12. OIT Project Management Office (PMO):

4.12.1. Ensuring standards, procedures, and practices are being followed to ensure projects are successful and return the expected value to the organization;

4.12.2. Managing project scope changes to leverage opportunities, optimizing shared objectives across projects, resourcing projects, and managing methodologies and metrics; and

4.12.3. Facilitating the sharing of resources, methodologies, tools, and techniques.

4.13. OIT Applications Development:

4.13.1. Working with agencies to ensure that:

4.13.1.1. Vendors meet the necessary security requirements; and

[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ApplicationDeploymentCertification.pdf

4.13.1.2. Any requested exceptions are submitted for evaluation and final approval by the CIO or the CISO through the waiver process.

4.14. Third-party service providers/vendors:

4.14.1. Implementing secure information systems, system components, and services that comply with the applicable federal and state laws and regulations, and ensuring compliance with the OIT contractual requirements and information security policies.

5.0. Management Commitment

The State of Maine is committed to following this policy and the supporting procedures.

6.0. Coordination Among Agency Entities

6.1. OIT works in close coordination with agencies to ensure alignment between the individual IT needs of the agency and the protection of the State of Maine network infrastructure.

6.2. OIT is a fee-for-service agency that also participates in the biennial budget process, identifying baseline funding requirements critical to safeguarding the State's information assets for inclusion within the state budget.

6.3. The service expectation and business needs of OIT's customers and partner agencies rely on a collaborative partnership between State agencies and OIT.

6.4. OIT fosters a collective appreciation among its partner agencies of the importance of securing the State's information technology (IT) infrastructure.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following procedures are designed to satisfy the security control requirements as prescribed under relevant federal and state laws, Executive Orders, rules, regulations, policies, and guidance.

8.1. **System and Services Acquisition Policy and Procedures (SA-1)**

8.1.1. This document fulfills SA-1 by establishing the policy and procedures for secure system and services acquisition across the State of Maine enterprise. It defines roles, responsibilities, lifecycle requirements, and acquisition controls aligned with NIST SP 800-53 Rev. 5. Updates to this document may be triggered by audit findings, security incidents, or changes in applicable laws, regulations, or standards.

8.2. **Allocation of Resources (SA-2):**

8.2.1. OIT works with agencies to:

8.2.1.1. Identify information security requirements for information systems and services in mission/business process planning; and

8.2.1.2. Ensure security costs are integrated into the agency's costs for services within acquisition processes.

8.2.2. As part of the biennial budget process:

8.2.2.1. The CISO works in partnership with OIT *Information Asset Owners* to determine the information security requirements for protection of the State's information systems and assets.

8.2.2.2. The CISO documents information security requirements for consideration by the CIO.

8.2.2.3. The CIO consolidates the OIT budget for approval. Once budget items are approved, the CISO allocates the necessary funds to protect the State's information systems and assets.

8.2.2.4. The CISO manages a discrete budget line for information security within OIT, which includes planning for resource allocation for initial acquisition and funding for the sustainment of the systems or services acquired.

8.2.3. OIT purchase requests for the acquisition of hardware, software, firmware, or media above $5,000 for use on the State of Maine network are made using the Purchase Request Form if not already specifically listed (i.e., individually by name) and approved as part of the biennial budget process. See Appendix A: OIT Purchase Request Form.

1.1 **System Development Life Cycle (SDLC) (SA-3, (1), (2)):**

8.2.4. OIT has documented System Development Life Cycle requirements in the Software Development Lifecycle (SDLC) Policy[6] and Procedures.[7]

8.2.4.1. The SDLC Policy and Procedures define and document security roles and responsibilities.

[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-policy.pdf
[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-procedure.pdf

8.2.5. The CISO, security architects, and other members of the ISO participate in development activities as required.

8.2.6. Security concerns are taken into consideration from SDLC planning through development phases as specified in General Architecture Principles,[8] which states "security and privacy are foundational to everything else."

8.2.7. Holding a robust, technical design review is a critical milestone in the SDLC. Design Review is conducted weekly as follows:

8.2.7.1. Technical experts from cross-functional teams within OIT meet to evaluate proposed solutions against State of Maine requirements.

8.2.7.2. Outcomes from the Design Review session vary depending on the age, status, and where in the SDLC the solution/project currently stands. Common deliverables include:

8.2.7.2.1. Areas of concern to address prior to proceed with the solution/project;

8.2.7.2.2. Security and compliance review and approval to proceed;

8.2.7.2.3. Feedback on feasibility and risk;

8.2.7.2.4. Requests for further solution diagrams and documentation; and

8.2.7.2.5. Requests for additional Design Review meetings as the solution/project progresses.

8.2.7.3. A thorough security vetting is required for every solution/project. Based on a review of the documentation material provided and information obtained during the meeting, the following security measures are identified:

8.2.7.3.1. High-risk aspects of the solution/project;

8.2.7.3.2. Architectural flaws;

8.2.7.3.3. Business risk potential;

8.2.7.3.4. Vulnerability detection;

8.2.7.3.5. Security of architecture, design, and open source/third-party components; and

8.2.7.3.6. Compliance requirements and data classification.

[8] http://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/general-architecture-principles_1.pdf

8.2.7.3.7. Personally Identifiable Information (PII) must not be used in non-production environments unless absolutely necessary. When production data is present in a non-production environment, that environment must implement security controls equal to or more stringent than those in the corresponding production environment.

8.2.7.4. As required, recommendations on remediation are presented to the solutioning/project team. Follow-up Design Review sessions may occur to discuss risks and steps for remediation.

8.2.8. Security is then considered through SLDC integration, testing, and implementation phases, as it must pass security testing as part of the Application Deployment Certification Policy.[9] Waivers to security are approved only as a part of a formal process outlined in the Waiver Policy;[10] this process is facilitated by the Architecture and Policy Team with approvals by either the CISO or the CIO.

8.2.8.1. The use of live or operational data in preproduction environments must be approved, documented, and controlled. Preproduction environments must be protected at the same impact or classification level as any live data in use.

8.2.9. Security is maintained through the remainder of the lifecycle process through assessments as outlined in Security Assessment and Authorization Policy and Procedures (CA-1)[11] and vulnerability management as outlined in Vulnerability Scanning Procedure (RA-5).[12] Furthermore, security of systems through changes is considered as a part of the Change Management Policy and Procedures.[13]

8.3. **Acquisition Process (SA-4, (1), (2), (9)):**

8.3.1. IT systems and services must meet the security requirements appropriate to the data they contain.

8.3.1.1. IT Procurement works with stakeholders to include State of Maine agencies, OIT teams, and vendors to document the appropriate security and compliance requirements that

[9] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification_0.pdf
[10] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[11] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/security-assessment-authorization-policy.pdf
[12] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/vulnerablity-scanning-procedure.pdf
[13] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/change-management-policy.pdf

must be met in the request for purchase and contract documentation.

8.3.1.2. The Policy Team facilitates a review of new technology documentation with the agencies, IT Procurement, and the ISO to determine that appropriate security and compliance requirements are met.

8.3.1.2.1. The Technical Assessment Form is a mandatory component of the State of Maine's Request for Proposal (RFP) process. It is used to evaluate whether proposed products, platforms, or technology stacks meet the State's architecture and security requirements.

8.3.1.3. Project managers support agencies in the acquisition of IT systems and services that meet security requirements appropriate to the data they contain, requiring the appropriate security approvals prior to implementation through project completion in accordance with General Architecture Principles.[14]

8.3.1.4. OIT supports agencies in their efforts to ensure that the applicable security and compliance requirements for their data are maintained throughout the system's lifecycle.

8.3.2. Before the acquisition of an IT system or service is completed, in addition to meeting security and compliance requirements, the following must also be documented and understood:

8.3.2.1. Acceptance criteria;

8.3.2.2. A description of the information systems development and deployment environments;

8.3.2.3. The location of systems that receive, process, or store agency data;

8.3.2.4. The functional properties, design, and implementation of security controls to be employed; and

8.3.2.5. The functions, ports, and services intended for organizational use.

8.3.2.6. Vendors must detail their approach to security controls related to authentication, encryption, vulnerability management, security monitoring, and incident response. Solutions must ensure the confidentiality, integrity, and availability of State data.

[14] http://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/general-architecture-principles_1.pdf

8.3.2.7. Through the Technical Assessment Form, bidders must provide thorough responses supported by clear explanations and list all proposed technologies. Umbrella solutions may be referenced by name if their security implications are addressed elsewhere in the response.

8.3.2.8. Acquisition documentation must include provisions for data ownership and return. Per the IT Service Contract (IT-SC), all data, notebooks, plans, working papers, and other works produced, and equipment and products purchased in the performance of the contract are the property of the Department or jointly with the Federal Government if federal funds are involved. The State shall have unlimited rights to use, disclose, duplicate, or publish all information and data developed or furnished under the contract. Per the OIT Confidentiality and Non-Disclosure Agreement (NDA), vendors must return or destroy all Confidential Information upon request or termination of services.

8.3.3. The minimum essential security standards that must be complied with prior to the acquisition through the deployment of IT systems and services include the following:

8.3.3.1. OIT Information Security Policy[15]

8.3.3.2. OIT Hosting and Housing Policy[16]

8.3.3.3. OIT Application Deployment Certification Policy[17]

8.3.3.4. OIT Application Deployment Certification Handbook[18]

8.3.3.5. OIT Remote Hosting Policy[19]

8.3.3.6. OIT Software Development Lifecycle Procedure[20]

8.3.3.7. OIT Software Development Lifecycle Policy[21]

8.3.3.8. OIT Change Management Policy[22]

[15] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/information-security-policy.pdf
[16] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/hosting-housing-policy.pdf
[17] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification_0.pdf
[18] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification-guidelines_1.pdf
[19] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/remote-hosting-policy.pdf
[20] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-procedure.pdf
[21] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-policy.pdf
[22] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/change-management-policy.pdf

8.3.3.9. OIT Confidentiality and Non-Disclosure Agreements for vendors with access to state and federally-protected data types (signed prior to granting access to data)

8.3.4. In addition to the minimum essential security standards considered in 8.4.3, IT systems and services that involve access to federally-protected data must document the security standards specified for that data type. Examples of documentation requirements include, but are not limited to, the following:

8.3.4.1. Use of a Health Insurance Portability and Accountability Act (HIPAA) Business Associate Agreements for *Protected Health Information* (PHI);

8.3.4.2. Inclusion of contract language from Exhibit 7 of Internal Revenue Service (IRS) Publication 1075,[23] Tax Information Security Guidelines for Federal, State, and Local Agencies Safeguards for Protecting Federal Tax Returns and Return Information for Federal Tax Information;

8.3.4.3. Service Level Agreements containing language as specified in the Electronic Information Exchange Security Requirements and Procedures for State and Local Agencies Exchanging Electronic Information with the Social Security Administration (SSA); and

8.3.4.4. All State of Maine IT contracts of any dollar amount must be accompanied by a completed Rider B-IT Agreement to Purchase Services, which requires OIT's review and approval and signature of the CIO (see Division of Procurement Services).[24]

8.3.4.5. As detailed in the Software Development Lifecycle (SDLC) Policy and Procedures[25], Application Owners are responsible for creating SDLC artifacts that capture technical documentation and operational expectations. Required artifacts include the Operations Manual and Deployment Plan, which document routine procedures and deployment readiness activities.

8.3.5. Only OIT-approved software may be used on the network.

8.3.5.1. All software purchases by state agencies must be pre-approved by the ISO through the change management process to mitigate risks of exploitation of covert channels.

[23] https://www.irs.gov/pub/irs-pdf/p1075.pdf
[24] https://www.maine.gov/dafs/bbm/procurementservices/forms
[25] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SDLCPolicy.pdf

8.3.5.2. A pre-approved list of software that has met security requirements is maintained by the Enterprise Architecture Team. The ISO has determined that these software applications must meet the security functionality, assurance, and documentation requirements to receive approval.

8.3.6. Absent a waiver from the ISO, the use of Freeware and Open Source Software (OSS) by an agency is prohibited. If the use of such Freeware or OSS is discovered by OIT, the agency may be subject to fines and penalties associated with the use of such software, including the cost of remediating any security risks caused by their use to the State of Maine network.

8.3.7. The ISO regularly scans the network to identify unauthorized hardware and/or software and notifies appropriate agency personnel when discovered.

8.3.8. All IT hardware and software assets must be assigned to a designated business unit or individual.

8.4. **Information System Documentation (SA-5):**

8.4.1. OIT only approves information systems for which proper documentation is provided and follows the aforementioned Policies and Procedures in 8.3 or 8.4. All documents are either produced by the State or the vendor.

8.4.2. Software Development Lifecycle Procedures[26] list the artifacts required for each corresponding SDLC Discipline Test.

8.4.3. Application Deployment Certification Policy[27] requires a summary result (Passed/Failed/Not Applicable) and a short paragraph clarifying that summary result, for a host of required tests (e.g., interfaces, security, performance).

8.4.4. What matters in terms of the artifacts required in 8.5.2 and 8.5.3 is the content, not the title. The information includes administrator and user documentation for the system, component, or service. Additional administrator and user documentation for the system, component, or service may be required as a function of the contract or project management documentation, as required by the PMO.

8.4.5. Submission of the artifacts in 8.5.2 and 8.5.3 does not preclude the necessity of submitting other project management documentation to the PMO concerning the overall management of the project. The PMO

[26] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-procedure.pdf
[27] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification_0.pdf

determines the scope and nature of the required project management documentation.

8.5. **Security Engineering Principles (SA-8, (14), (18), (22), (23), (31), (32), (33)):**

8.5.1. The following security engineering principles for new technology or technology undergoing major upgrades should be considered as part of the SLDC procedures outlined in 8.3 of this Policy:

8.5.1.1. Security is layered to create a defense in depth;

8.5.1.2. Security controls, policy, and architecture are arranged as recommended by the National Institute of Standards and Technology (NIST);

8.5.1.3. Security is foundational to everything else to include SDLC;

8.5.1.4. Clear physical and logical security boundaries should be established;

8.5.1.5. System developers are trained to develop secure software;

8.5.1.6. Security controls are established appropriate to the data and network it is engineered to protect; and

8.5.1.7. Security controls are appropriate to lower the risk a system poses to an acceptable level.

8.5.2. Personnel interacting with systems must be provided with sufficient documentation and training to support secure system use. Documentation must be written clearly and supported by training that promotes security awareness and understanding of security-relevant responsibilities.

8.5.3. Agencies are responsible for implementing data minimization principles within their systems and processes. Minimization must be driven by legitimate business needs, clearly documented, and coordinated with the appropriate agency privacy official to ensure alignment with enterprise privacy and security expectations.

8.5.4. IT solutions must restrict access rights to the minimum necessary for users, processes, and services to perform their authorized functions.

8.5.5. Data transmissions must be appropriately encrypted as detailed in System and Communications Protection Policy and Procedures for Encryption Mechanisms (SC-12, SC-13, SC-17).

8.5.6. Non-repudiation ensures that actions performed by individuals or processes within the system cannot be denied. This is achieved through cryptographic techniques, audit logging, and strict access controls. See Audit and Accountability Policy and Procedures.

8.5.7. OIT Information Asset Owners establish, document, and implement Common Secure Configurations using industry standards or trusted vendors. Configurations must reflect the most restrictive mode consistent with operational requirements. See Configuration Management Policy and Procedures.

8.5.8. Security Impact Analysis (SIA) is conducted prior to system modifications as outlined in the Change Management Policy to ensure continued system trustworthiness.

8.6. External Information System Services (SA-9, (1), (2), (3), (5), (6), (8))

8.6.1. Plans to outsource information system services that handle select federally provided data types require advanced notifications and approval as required by the respective federal agencies (e.g., IRS, SSA, Centers for Medicare and Medicaid Services, etc.).

8.6.2. The use of systems other than those owned by the State of Maine that handle select federally provided data types requires advanced notifications and approval as required by the respective federal agencies (e.g., IRS).

8.6.3. Changes to the systems that handle select federally-provided data types require advanced notifications and approval as required by the respective federal agencies (e.g., SSA).

8.6.4. *Cloud service providers* that receive, process, store, or transmit data types classified as sensitive and restricted (i.e. TLP: Amber, TLP: Amber+Strict or TLP: Red), which include federally-protected data, must have one of the following, or a combination thereof, acceptable third-party audit reports (see SA-11 for further information):

8.6.4.1. Absent a GovRAMP Authorized designation, a current GovRAMP Security Snapshot must be submitted prior to contract award.

8.6.4.2. Maintain a *Federal Risk and Authorization Management Program (FedRAMP)* certification for the appropriate data impact level (e.g., Moderate, High);

8.6.4.3. Provide annually a *Service Organization Control (SOC) 2 Type II* audit report with the appropriate trust principles.

8.6.4.4. Maintain an *International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) 27001* certification; or

8.6.5. The oversight roles and responsibilities regarding *external information system services* are shared between OIT and the agencies. The delineation of these is specified in this document.

8.6.6. IT Procurement assists agencies in documenting expectations of performance with vendors through Service Level Agreements (SLAs), Data Exchange Agreements (DUAs), and contracts.

8.6.7. The ISO assists agencies that are responsible for determining the TLP classification of all data used and held by their agency and vendors. The TLP classification determines the level of information security required for an acquisition or outsourced information service to lower the risk of that data to an acceptable level.

8.6.8. External service providers identify the functions, ports, protocols, and other services required for the use of such services as part of design review and deployment certification.

8.6.9. OIT shall establish, document, and maintain trust relationships with external service providers based on defined security and privacy requirements. These relationships must be governed by formal agreements, such as contracts, SLAs, or DUAs, that define control expectations, acceptable risk levels, roles and responsibilities, performance obligations, and data protection provisions. All external providers must undergo appropriate security due diligence through reviews, which may include third-party audits, compliance certifications, or equivalent assurance artifacts. Providers handling sensitive or regulated data must submit attestation of compliance with confidentiality and non-disclosure agreements (NDAs). Contracts must include provisions allowing the State to audit, review, or request evidence of control effectiveness throughout the engagement. Agencies must coordinate with OIT Information Security and IT Procurement to ensure trust thresholds are met and oversight is maintained.

8.6.10. OIT ensures the integrity and confidentiality of organizational data transmitted to or stored within external systems by maintaining exclusive control over cryptographic keys for systems and services it directly manages. This includes all on-premises infrastructure and select approved cloud platforms where the State retains full ownership and management of encryption keys. For vendor-hosted environments, OIT enforces contractual obligations and regulatory compliance mandates to prevent unauthorized access to encryption keys. No external party may access encryption keys unless explicitly authorized under those contract terms.

8.7. Developer Configuration Management (SA-10):

8.7.1. OIT's configuration management policies are outlined in Configuration Management Policy and Procedures[28].

[28] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ConfigurationManagementPolicy.pdf

8.7.2. Configuration management for system, service, or component development is determined and performed:

8.7.3. In development, as a part of design review, as determined by the agency and OIT;

8.7.4. In implementation, and verified through the deployment certification process; and

8.7.5. In operation, as a part of required audits and vulnerability management.

8.7.6. The integrity of changes made is documented and managed in the Enterprise Ticketing System as outlined in Change Management Policy and Procedures [29] and Jira Software is used for application development.

8.7.7. The OIT CAB approves changes that are then implemented using a risk-based approach. Approval follows a documented Request for Change (RFC) process, based on the type of RFC (e.g., Normal, Emergency).

8.7.8. Third party vendors must configure their services in a secure manner. Developer configuration management is addressed through deployment certification, contractual obligations, and audits as appropriate.

8.7.9. Security waivers must be approved by the CISO that arise due to vulnerability scans conducted prior to deployment. Vulnerabilities must be remediated or waived as outlined in the Application Deployment Certification Policy. [30]

8.7.10. OIT security flaw resolution and reporting requirements are outlined in the OIT Vulnerability Scanning Procedures (RA-5) [31] and Incident Reporting Procedures (IR-6) [32] (available on the intranet only). Other OIT policies outline the resolution of security flaws during the development of information systems, the implementation of system components, or the operation of information system services.

8.7.11. All software and firmware changes, whether developed internally or procured from external vendors, must undergo integrity verification. Internal developers must follow OIT's configuration management processes, including baseline configurations, PKI certificate verification, and documented change control via the Change Advisory Board. Sensitive components (e.g., OS patches, BIOS/UEFI, device drivers, security modules) must be verified using trusted digital signatures and deployed only after approval and testing. External vendors must comply with Configuration Management and System and Services Acquisition

[29] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/change-management-policy.pdf
[30] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification_0.pdf
[31] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/vulnerablity-scanning-procedure.pdf
[32] https://inet.state.me.us/oit/policies/documents/IncidentReportingProcedures.pdf

policies and procedures, and meet applicable NIST SP 800-53 baselines based on system sensitivity.

8.7.12. Hardware components managed by OIT must meet baseline configuration requirements, access control restrictions, and device compliance monitoring standards. Devices connecting to the State network are subject to endpoint protection and automated quarantine if noncompliant. External vendors must comply with Configuration Management and System and Services Acquisition policies and applicable NIST SP 800-53 baselines. Vendors must demonstrate hardware integrity verification capabilities, such as digitally signed firmware or secure boot processes, and ensure lifecycle integrity assurance.

8.7.13. Designated security representatives are embedded in the configuration change management and control process. Agency privacy representatives are engaged during development and are responsible for ensuring vendors uphold privacy representation requirements within their own configuration change control processes.

8.8. **Developer Security Testing and Evaluation (SA-11, (1), (2), (4), (5), (8)):**

8.8.1. OIT follows OIT deployment certification protocols, policies, and procedures.

8.8.2. OIT assists agencies in the development of security assessment plans to meet federal regulatory requirements or as otherwise required.

8.8.3. OIT performs unit, integration, system, regression, and security testing and evaluation as required.

8.8.4. Flaws are remediated as required according to the OIT Vulnerability Scanning Procedures (RA-5)[33] and the deployment certification protocols, policies, and procedures.

8.8.5. The results of security testing and the execution of the security assessment plan are recorded in the Enterprise Ticketing System.

8.8.5.1. The execution of the security assessment plan is documented as necessary to meet federal regulatory requirements or as otherwise required.

8.8.6. OIT typically reviews static code to identify and remediate common flaws in different environments (e.g., test, development) as a part of deployment, implementation, and operations (**CE-1**).

8.8.7. Vendors are reviewed for their ability to provide the required security appropriate to their product.

[33] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/vulnerablity-scanning-procedure.pdf

8.8.8. All vendors must meet minimum security requirements to the satisfaction of the CISO and CIO. These vendors include those providing *Infrastructure as a Service (IaaS), Platform as a Service (PaaS), or Software as a Service (SaaS)*.

8.8.9. All CSPs that receive, process, store, or transmit data types categorized as TLP: Amber, TLP: Amber+Strict, or TLP: Red must submit an approved certification or acceptable third-party audit report. See Appendix B - Cloud Service Provider Security Requirements for more details.

8.8.10. Threat modeling and vulnerability analysis incorporate contextual information including acceptable risk levels, threat intelligence, operational environment, and system impact. These processes are coordinated between the Security Operations Center (SOC) and the Governance, Risk, and Compliance (GRC) team. Organization-defined tools such as vulnerability scanners, centralized log analysis platforms, and enterprise risk management systems support both proactive and reactive analysis. The rigor of modeling is based on system classification and data sensitivity. Evidence includes documented risk assessments, vulnerability tracking, and security review artifacts. Control waivers are governed by the CISO and reviewed by the Information Security Architect and Enterprise Architecture and Policy section.

8.8.11. Developers must review code using both manual and automated mechanisms to ensure application security and integrity. This dual-layered review process identifies vulnerabilities, enforces secure coding practices, and verifies alignment with organizational security requirements throughout the development lifecycle.

8.8.12. Penetration testing is conducted to fulfill regulatory compliance obligations and may also be performed on an ad hoc basis at the direction of the Chief Information Security Officer (CISO). This approach ensures testing is strategically targeted and responsive to emerging threats or operational changes.

8.8.13. Dynamic code analysis is performed using automated tools that execute applications in a runtime environment to detect vulnerabilities during operation. See Vulnerability Management Procedures and Software Development Lifecycle Policy and Procedures.

8.9. **Development Process, Standards, and Tools (SA-15, (3), (12)):**

8.9.1. All system, component, and service development must follow a documented and structured process that integrates security as a core architectural principle, as outlined in the General Architecture Principles. Agencies, as data owners, are responsible for ensuring privacy requirements are addressed throughout the development process.

8.9.2. Development requirements, including applicable standards, approved tools, and configurations, are defined in the Application Deployment Certification Guidelines, Policy, and supporting templates. These resources ensure development activities align with both functional objectives and the State's security expectations.

8.9.3. Specific tool options and configurations used during development are determined by the relevant technology owners. Their effectiveness is validated through the deployment certification process to ensure alignment with security and operational standards.

8.9.4. Tool selections and configurations must be formally documented and controlled within the deployment certification process. The integrity of changes to development tools and processes is governed under the OIT Change Management Policy, which requires formal review, approval, and tracking.

8.9.5. The collection, use, sharing, and disposal of Personally Identifiable Information (PII) must be limited to the minimum necessary to support a legitimate, legally authorized business purpose. Agency-designated data owners are responsible for determining the necessity of each PII element collected and must ensure appropriate documentation and disclosure in accordance with the System and Information Integrity Policy and Procedures.

8.10. **Developer Security and Privacy Architecture and Design (SA-17):**

8.10.1. Developers must produce a design specification and supporting security and privacy architecture that aligns with the State of Maine's policies and procedures, as defined in OIT's General Architecture Principles and related governance documents.

8.10.2. Security architecture reviews must ensure that required controls, such as access control, logging, and segmentation, are accurately and completely described, with clear allocation across physical and logical system components.

8.10.3. Controls must be designed to work cohesively to deliver integrated protection outcomes that reduce unnecessary data exposure and enhance privacy as a secondary benefit.

8.10.4. Agencies are responsible for ensuring that the use of data is minimized to only essential elements, and that personally identifiable information (PII) does not propagate through systems without documented, legitimate justification.

8.11. **Developer Screening (SA-21):**

8.11.1. All developers of systems, system components, or system services must have appropriate access authorizations as determined by authorized agency personnel. Access approvals are governed by the Access Control

Policy and Procedures, which define roles, responsibilities, and processes for granting access.

8.11.2. Developers must also satisfy personnel screening requirements. For internal personnel, including state employees and contractors, screening is governed by the Personnel Security Policy and Procedures. For external vendors, background check requirements are specified in their contracts and must reflect the same expectations.

8.12. **Unsupported System Components (SA-22)**

8.12.1. OIT strives to make the best possible use of its IT dollars by eliminating waste and promoting efficiency.

8.12.2. Within available resources, OIT replaces information system components when support for the components is no longer available from the developer, vendor, or manufacturer, and provides justification and documentation of the approval for the continued use of unsupported system components required to satisfy the agency's mission/business needs.

8.12.3. When necessary, if agencies or OIT require the continued use of unsupported system components, outdated applications, or hardware, the entity must provide justification and documents for approval by the CISO or CIO through the waiver or budget process for the continued use of unsupported system components.

8.13. **Specialization (SA-23):**

8.13.1. OIT and agencies must employ design, modification, augmentation, or reconfiguration on systems or system components that support mission-essential services or functions to increase their trustworthiness. These enhancements may include supplemental authentication, non-repudiation functions, or other mechanisms that strengthen the integrity and reliability of critical resources.

8.14. No Expectation of Privacy

8.14.1. Information assets created, purchased, leased, or licensed by the State of Maine, including, but not limited to, software (e.g. application software, application source code, systems software), physical equipment (e.g. computers, portable devices, tablets, smartphones), communications equipment (e.g. routers, switches, firewalls), electronic media (e.g. disks, tapes), services (e.g. Internet, communications, cloud), and information (e.g. databases and data files, system documentation, network diagrams), are the property of the State of Maine. As such, the State has the absolute right to monitor the use of such property. Accordingly, users of State information assets may not assume their actions or use of State information assets are private or protected.

9.0. Document Details

9.1. Initial Issue Date: October 30, 2020

9.2. Latest Revision Date: December 12, 2025

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology [34]

9.6. Waiver Process: Waiver Policy [35]

9.7. Distribution: Internet [36]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance [37] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA), [38] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as to security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Application Deployment Certification Guidelines: A set of standards, templates, and policies that define development requirements, approved tools, and configurations for secure application deployment.

13.2. Availability: Timely and reliable access to and use of information assets.

---

[34] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[35] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[36] https://www.maine.gov/oit/policies-standards
[37] https://www.maine.gov/sos/arc/records/state/GS1Administrative.pdf
[38] https://legislature.maine.gov/statutes/1/title1sec402.html

13.3. Change Advisory Board (CAB): A governance group responsible for reviewing and approving system changes based on risk, impact, and documented RFC processes.

13.4. Cloud Service Provider: an organization that provides cloud services. Cloud computing is a model that enables ubiquitous, convenient, on-demand access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or interaction with the service provider.

13.5. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.6. Confidentiality and Non-Disclosure Agreement (NDA): A contractual document requiring vendors to return or destroy confidential information upon request or termination of services.

13.7. Criticality Analysis: A structured evaluation of system components at key SDLC stages to determine their importance to mission-essential functions and risk posture.

13.8. Deployment Certification: A formal process that validates system readiness, security controls, and documentation prior to production deployment.

13.9. Design Review: A formal intake process used to vet new technology solutions and support SDLC milestones. Facilitated by OIT to ensure alignment with architectural and security expectations.

13.10. Dynamic Code Analysis: The use of automated tools to execute applications in a runtime environment to detect vulnerabilities during operation.

13.11. Enterprise Architecture Review Board (EARB): A governance body convened by the Enterprise Architect to evaluate strategic architectural decisions, ensure alignment with enterprise principles, and support oversight of major acquisitions and system changes.

13.12. External Information System Services: services that are implemented outside of the authorization boundaries of organizational information systems. This includes services that are used by, but not a part of, organizational information systems. Organizations using external service providers that process, store, or transmit federal information or operate information systems on behalf of the federal government must ensure that such providers meet the same security requirements as federal organizations. (Source: NIST 800-53).

13.13. FedRAMP: a government-wide program that provides a standardized approach to security assessment, authorization, and continuous monitoring for cloud products and services.

13.14. General Architecture Principles: Foundational design and governance standards that guide system development, integration, and security alignment across the enterprise.

13.15. Governance, Risk, and Compliance (GRC): A cross-functional team that coordinates risk assessments, policy alignment, and compliance activities.

13.16. GovRAMP Security Snapshot: A preliminary security profile submitted by vendors prior to contract award when full GovRAMP authorization is pending.

13.17. Information Asset: Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.18. Information Asset Owner: Information Asset is used interchangeably with Information System and is a discrete, identifiable piece of IT, including hardware, software, and firmware. Ownership of Information Assets is listed in the OIT Information Systems Contingency Plan (CP-2).[39]

13.19. Infrastructure as a Service (IaaS): the capability provided to the consumer is the provision of processing, storage, networks, and other fundamental computing resources where the consumer is able to deploy and run arbitrary software, which can include operating systems and applications. The consumer does not manage or control the underlying cloud infrastructure, but has control over operating systems, storage, and deployed applications, and may have limited control over select networking components (e.g., host firewalls).

13.20. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.21. ISO/IEC 27001: Internationally accepted standards and requirements for an information security management system (ISMS), though there are more than a dozen standards in the ISO/IEC 27000 family. Using these standards enables organizations of any kind to manage the security of assets, such as financial information, intellectual property, employee details, or information entrusted by third parties. Certification by an independent body provides the necessary written assurance (a certificate) that the product, service, or system in question meets the specific ISO/IEC 27001 requirements.

13.22. Personal Identity Verification (PIV)-like capabilities: Authentication mechanisms such as smart card login or secure token access that use FIPS 140-validated cryptographic modules.

[39] https://inet.state.me.us/oit/policies/documents/InformationSystemsContingencyPlan.pdf

13.23. Personally Identifiable Information (PII): Information which can be used to distinguish or trace the identity of an individual (e.g., name, social security number, biometric records, etc.) alone, or when combined with other personal or identifying information which is linked or linkable to a specific individual (e.g., date and place of birth, mother's maiden name, etc.).

Source: NIST CSRC Glossary.[40] Maine state law does not define PII, but rather provides a more limited definition of "personal information" within the context of the Maine Notice of Risk to Personal Data Act (see 10 M.R.S. §1347).[41]

13.24. Platform as a Service (PaaS): the capability provided to the consumer to deploy onto the cloud infrastructure consumer-created or acquired applications created using programming languages, libraries, services, and tools supported by the provider. The consumer does not manage or control the underlying cloud infrastructure, including network, servers, operating systems, or storage; they have control over the deployed applications and possibly configuration settings for the application-hosting environment.

13.25. Protected Health Information (PHI): individual health information held by covered entities subject to the HIPAA Privacy and Security Rules. These Rules provide federal protections for personal health information held by covered entities and grant patients an array of rights with respect to that information.

13.26. Security Architecture Review: A formal evaluation of system design to ensure controls such as access, logging, and segmentation are accurately described and allocated.

13.27. Security Impact Analysis (SIA): A formal assessment conducted prior to system modifications to ensure continued trustworthiness. Governed by the Change Management Policy.

13.28. Security Operations Center (SOC): A centralized team responsible for monitoring, analyzing, and responding to security threats across the enterprise.

13.29. Security Review Artifacts: Documentation generated during threat modeling, vulnerability analysis, or deployment certification that supports audit and waiver decisions.

13.30. SOC 2 Type I: A report that details the suitability of the design controls to the service organization's system. It details the system at a specific point in time, including its scope, organizational management, system description, and the controls in place. SOC 2 Type I report shows that a SaaS firm has best practices in place. Generation of a SOC 2 Type I report is also quick after a service entity completes a readiness assessment. This report should be used

[40] https://csrc.nist.gov/glossary
[41] http://legislature.maine.gov/legis/statutes/10/title10sec1347.html

when shopping for a third-party vendor, especially since the other type of SOC 2 report, Type 2, can take up to a year to be completed.

13.31. SOC 2 Type II: A report that demonstrates a thorough examination by a third-party accounting and auditing firm of an organization's internal control policies and practices over a specified period of time; the report shows the firm has reviewed and examined an organization's control objectives and activities, and tested those controls to ensure that they are operating effectively. Adherence to specific Trust Service Principles is required to successfully achieve certification, which includes: Security, Availability, Processing Integrity, Confidentiality, and Privacy. These reports are intended to meet the needs of a broad range of users who need detailed information and assurance about the controls at a service organization relevant to security, availability, and processing integrity of the systems the service organization uses to process users' data and the confidentiality and privacy of the information processed by these systems.

13.32. Software as a Service (SaaS): The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure. The applications are accessible from various client devices through either a thin client interface, such as a web browser (e.g., web-based email), or a program interface. The consumer does not manage or control the underlying cloud infrastructure, including network, servers, operating systems, storage, or even individual application capabilities, with the possible exception of limited user-specific application configuration settings.

13.33. Technical Assessment Form: A mandatory RFP component used to evaluate proposed technologies against architecture and security requirements. (See: IT RFP Template [42] Technical Assessment Appendix) (Internal only).

13.34. Threat Modeling: A proactive process that identifies potential threats to systems based on contextual factors such as risk level, operational environment, and system impact.

13.35. Traffic Light Protocol (TLP): The Cybersecurity and Infrastructure Security Agency (CISA) Traffic Light Protocol (TLP) is used by OIT for classifying the impact level of PII. OIT's five data, communication, or network classification levels are Public (TLP: Clear), Internal (TLP: Green), Sensitive (TLP: Amber; TLP: Amber+Strict), and Restricted (TLP: Red). (See Risk Assessment Policy and Procedure (RA)) [43]

14.0. Abbreviations

14.1. CAB: Change Advisory Board

[42] https://stateofmaine.sharepoint.com/:w:/r/sites/DAFS-Procurement-Services-Intranet/Shared%20Documents/Public%20to%20intranet/FORMS/Competition%20Documents/IT-RFP%20Template_%20Final%20(2)%2010-1-25.docx?&d=1

[43] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/risk-assessment-policy-procedure.pdf

14.2. DAFS: Department of Administrative and Financial Services
14.3. DUA: Data Exchange Agreement
14.4. EARB: Enterprise Architecture Review Board
14.5. FedRAMP: Federal Risk and Authorization Management Program
14.6. FOAA: [Maine] Freedom of Access Act
14.7. GRC: Governance, Risk, and Compliance
14.8. IaaS: Infrastructure as a Service
14.9. ISO/IEC: International Organization for Standardization / International Electrotechnical Commission
14.10. NDA: Non-Disclosure Agreement
14.11. NIST: National Institute of Standards and Technology
14.12. OIT: Office of Information Technology
14.13. PaaS: Platform as a Service
14.14. PHI: Protected Health Information
14.15. PII: Personally Identifiable Information
14.16. PIV: Personal Identity Verification
14.17. RFP: Request for Proposal
14.18. SaaS: Software as a Service
14.19. SDLC : Software Development Lifecycle
14.20. SIA: Security Impact Analysis
14.21. SOC: Security Operations Center
14.22. TLP: Traffic Light Protocol

Appendix A: Cloud Service Provider Security

1.0 REQUIREMENTS

1.1 All Cloud Service Provider (CSP) vendors must meet minimum security standards and annually report and document their compliance posture. These vendors include those providing Infrastructure as a Service (IaaS), Platform as a Service (PaaS), or Software as a Service (SaaS). The minimum essential security standards that must be considered for the acquisition of IT systems and services include the following:

1.1.1 OIT Information Security Policy[44]
1.1.2 OIT Hosting and Housing Policy[45]
1.1.3 OIT Application Deployment Certification Policy[46]
1.1.4 OIT Application Deployment Certification Handbook[47]
1.1.5 OIT Remote Hosting Policy[48]
1.1.6 OIT Software Development Lifecycle Procedure[49]
1.1.7 OIT Software Development Lifecycle Policy[50]
1.1.8 OIT Change Management Policy[51]

1.2 All CSPs that receive, process, store, or transmit data types categorized as TLP: Amber, TLP: Amber+Strict or TLP: Red must submit one of the following, or a combination thereof, acceptable third-party audit certificate of certification, or reports:

1.2.1. Absent a GovRAMP Authorized designation, a current GovRAMP Security Snapshot must be submitted prior to contract award.
1.2.1 FedRAMP certification in accordance with the appropriate data impact level (High, Moderate, or Low) as determined by the State and Vendor;
1.2.2 Service Organization Control (SOC) 2 Type II audit report with the appropriate trust principles.
1.2.3 ISO/IEC 27001 certification; or

1.3 For SOC 2 Type II audits, OIT and the agency will determine which of the five trust principles will be required (Security, Availability, Processing Integrity, Confidentiality, and Privacy). However, general guidance on the trust principles required based on the type of cloud service provided is listed in Figure 1.

---

[44] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/information-security-policy.pdf
[45] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/hosting-housing-policy.pdf
[46] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification_0.pdf
[47] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/application-deployment-certification-guidelines_1.pdf
[48] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/remote-hosting-policy.pdf
[49] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-procedure.pdf
[50] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/sdlc-policy.pdf
[51] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/change-management-policy.pdf

Figure 1: Responsibility for Security Across Cloud Service Models

ENTITY WITH PRIMARY RESPONSIBILITY FOR ENSURING SECURITY ACROSS CLOUD SERVICE MODELS			
TSP	**IaaS**	**PaaS**	**SaaS**
Security	Service Provider	Service Provider	Service Provider
Availability	Service Provider	Service Provider	Service Provider
Processing Integrity	State	Service Provider / State	Service Provider
Confidentiality	State	Service Provider / State	Service Provider
Privacy	State	Service Provider / State	Service Provider

1.4 While a vendor is not necessarily required to address all five of the Trust Services Criteria in its SOC 2 audit report, it should include the categories that are relevant to the services they are providing to State of Maine (State of Maine) agencies.

1.4.1 Security – In a non-privacy SOC 2 engagement, the security category must be included. Security is the common criterion that applies to all engagements and is what the other Trust Services Criteria are based on. The security category addresses whether the system is protected (both physically and logically) against unauthorized access.

1.4.2 Confidentiality - If the services the vendor offers deal with sensitive data, such as *Personally Identifiable Information* (PII) or Protected Health Information (PHI), the confidentiality category should be present in their SOC 2 audit report. The confidentiality principle addresses the agreements that the vendor has with clients in regard to how the vendor uses State of Maine information, who has access to it, and how the vendor protects it. *Is the vendor following its contractual obligations by properly protecting the State of Maine's information*?

1.4.3 Availability – *Is the vendor ensuring that the system they provide to State of Maine agencies is available for operation and used as agreed?* Availability addresses whether the services a vendor provides are operating with the type of availability that a State of Maine agency would expect. The availability category typically applies to companies providing colocation, datacenter, or hosting services to their clients.

1.4.4 Processing Integrity - If the services a vendor provides are financial services or e-commerce services and are concerned with transactional integrity, processing integrity is a category that should be included in the SOC 2 report. *Are the services the vendor provides to State of Maine agencies provided in a complete, accurate, authorized, and timely manner? Is the vendor ensuring that these things are happening?*

1.4.5 Privacy – Privacy is distinct from the other four and usually is in a separate report. The privacy category really stands on its own, as it specifically addresses how a vendor collects and uses consumers' personal information. It ensures that the vendor is handling client data in accordance with any commitments in the entity's privacy notice as committed or agreed, and with criteria defined in generally accepted privacy principles issued by the American Institute of Certified Public Accountants (AICPA).

1.5 CSPs are responsible for the costs associated with fulfilling the audit requirements.

1.6 OIT and the CSP will establish an agreed-upon timeline for the initial audit and report deliverables. The timing of a SOC 2 Type II audit should begin no later than 12 months after production data is utilized (i.e., if production data is used in the test environment, the SOC 2 Type II clock starts). However, an audit for a new service may be conducted no later than 18 months after the initial purchase.

1.7 The SOC 2 Type II audit period should cover the following 12 months. The completed SOC 2 Type II report should be provided to the OIT ISO within three months after the audit period.

1.8 A SOC 2 Type II audit must be completed annually thereafter and the results provided to the State.

1.9 Absent a SOC 2 Type II, a *SOC 2 Type I* will be provided. OIT and the CSP will establish an agreed-upon timeline for the initial audit and report deliverables. The timing of a SOC 2 Type I audit should begin no later than 4 months after production data is utilized (i.e., if production data is used in the test environment, the SOC 2 Type II clock starts).

1.9.1 Because a SOC 2 Type I is as of a point-in-time, if a service organization has its controls in place and documented, an examination may be performed right away, and a report generated. This report should be provided to the ISO for review.

1.9.2 If controls are not in place, a pre-assessment or readiness assessment should be completed first, and then a period of remediation will generally follow. Once controls are designed and in place, walkthroughs and testing of those controls can take place, and a report can be generated. This report should be provided to the ISO for review.

1.10 If a vendor is unable to meet any of the above requirements, a waiver will be required by the ISO.

1.11 An ISO waiver will be required for:

1.11.1 Contracts with CSPs for a SOC 2 Type II audit that does not include all five trust principles to document the approval of the trust principles used;

1.11.2 Contracts with CSPs that do not have a SOC 2 Type II, which exceed 12 months after production data is utilized;

1.11.3 Contracts with CSPs, absent a SOC 2 Type II that does not have a SOC 2 Type I, which exceeds the 4 months after production data is utilized; or

1.11.4 Any determination that cloud services should be classified as TLP: Clear or Green (low impact level), and therefore not subject to the third-party audit requirements.

1.12 GovRAMP Security Snapshot and Assessment Clause

1.12.1 Absent a GovRAMP Authorized designation, a current GovRAMP Security Snapshot must be submitted prior to contract award. Vendors must achieve and document GovRAMP Authorized status within twelve (12) months of using production data.

1.12.2 The vendor must maintain active enrollment for the product in the GovRAMP Progressing Security Snapshot Program throughout the certification process.

Vendors must submit monthly progress reports to the State demonstrating measurable advancement toward GovRAMP Authorized status. Reporting is required for the duration of the certification effort.

1.12.3 Any Cloud Service Provider (CSP) that does not possess a current GovRAMP Authorized, FedRAMP Authorized, or SOC 2 Type II attestation at the time of contract execution must include binding contract language establishing a timeline for the product achieving the required assessment. Agencies are encouraged to include contract language that failure to meet the agreed-upon assessment milestone(s) shall result in financial penalties, to be assessed monthly, and/or other remedies as determined by the State.

1.12.4 Assessment Requirement and Penalty Clause:

1.12.4.1 Any Cloud Service Provider (CSP) that does not possess a current GovRAMP Authorized, FedRAMP Authorized, or SOC 2 Type II attestation at the time of contract execution must enter into a waiver agreement prior to any exception approval. The waiver must include:

1. A clear timeline for achieving full certification;
2. Identification of interim assessment status (e.g., GovRAMP Security Snapshot);
3. A contractual obligation for monthly progress reporting;
4. Acknowledgement that continued non-compliance may result in contract termination or other remedies as deemed appropriate by the State.

1.12.4.2 Any proposed liquidated damages language must be incorporated into the waiver by the agency. No waiver will be approved unless all of these terms are fully and contractually incorporated.

1.13 Agencies may request a third-party audit of a CSP for certain data types that are not categorized as classified or restricted (i.e. TLP:Amber, TLP: Amber+Strict, or TLP:Red, if the Agency determines that the service supports an essential business function.

1.14 SaaS vendors cannot use IaaS certification unless the application is explicitly covered as part of the IaaS assessments.

1.15 The CSP is required to plan, implement, and communicate the status of corrective actions taken/planned to remediate any identified vulnerabilities.

1.16 The final third-party security review or certification requirements to be met by the vendor, and the date to meet this requirement, will be determined as a function of delivery method and date of the service provided. However, the audit or certification plan must be to the satisfaction of the ISO and be specified in the contract.

1.17 All third parties and providers of external information system services must define and document how they are compliant with statewide information security controls, including user roles and responsibilities, and compliance auditing and reporting requirements.

1.18 OIT reviews and monitors all services, outputs, and products provided by third parties at least on an annual basis.